Team Caffeinated Nerds · Challenge: **Frontier · PS-04** · Fast and Secure Online Transaction Authentication

Bhavyam Misra
Roll No: 1024030535

Gunagye Jain
Roll No: 1024030019

Abhijay Nagal
Roll No: 1024170013

Shefali Sharma
Roll No: 1024030284

Problem, Stakeholder & SDGs

> Fraud has moved past OTPs: victims now approve the payment themselves

THE PROBLEM

Asha, 72, gets a call from a fake "CBI officer". On her own phone, at home, she types her own UPI PIN. Right person, right phone, right PIN: the bank **approves ₹85,000 to a scammer**.

> A PIN checks **who** you are. Nobody checks **what's happening**.

WHO IT'S FOR

Banks, UPI apps and payment gateways, who must decide inside UPI's 15-second window, on behalf of everyday payers, especially seniors and first-time users.

WHY IT'S WORTH SOLVING

RBI's proposed fix is a 1-hour delay on every payment above ₹10,000. That slows every honest user too. A check that reads the situation can stop the scam and leave honest payments alone.

EVIDENCE

₹22,495 cr
lost to cyber fraud in India in 2025 (MHA, NCRP data)

85%
of that came from investment (76%) and "digital arrest" (9%) scams, where victims send the money themselves (MHA)

98.5%
of fraud value is in payments above ₹10,000; account-takeover fraud is "now negligible" (RBI, 9 Apr 2026)

PRIMARY · SDG 16
16.4: cut illicit financial flows & organised crime

SUPPORTING · SDG 8
8.10: access to financial services for all

SUPPORTING · SDG 9
9.1: reliable, resilient (digital) infrastructure

Sources: MHA/NCRP via ThePrint (2025 losses by scam type); RBI Discussion Paper "Exploring safeguards in digital payments to curb frauds", 9 Apr 2026. Links: github.com/bhavyammisra/BIOS-Transaction-Authentication

Existing Approaches & Gap

> Today's defences check the credential or the receiver, never the moment

1. Static two-factor auth

UPI PIN · SMS OTP · 3-D Secure

What it does

Device binding plus a PIN or OTP on every payment. RBI keeps 2FA as the minimum from April 2026.

What's still missing

Checks the credential, not the context. A coached victim types it in; a SIM swap steals it. A ₹50 tea and a ₹2 lakh transfer get the same check.

2. Commercial risk engines

Stripe Radar · Sift · BioCatch

What it does

Machine-learning scores over hundreds of signals; the merchant or bank sets block, review or step-up rules.

What's still missing

Closed, inside one provider's network. The output is a score for an analyst, not a reason for the customer. A high score triggers the same OTP or 3DS whatever the kind of risk.

3. India's shared intelligence

NPCI FRM · DoT FRI · RBI MuleHunter.AI

What it does

Flags risky phone numbers and mule accounts across banks and UPI apps.

What's still missing

Works after the fact: a number must be reported first, and scam numbers live for days. It scores the receiver, not what is happening in this session.

The gap we are addressing is: no lightweight, real-time service combines behaviour, device and transaction context into an explained allow / challenge / block decision, and picks the kind of challenge that actually stops the risk in front of it.

Sources: RBI Authentication Directions (25 Sep 2025) & Discussion Paper (9 Apr 2026); Stripe Radar risk-evaluation docs; Sift; BioCatch; NPCI FRM; DoT FRI (May 2025). Full links: repo › docs/02-research/prior-art.md

BIOS

Proposed Solution

> Pramaan: a PIN checks who you are. We check what's happening, before every payment.

WHAT WE BUILD

A cloud risk API that a bank or UPI app calls **before** the PIN step. It returns allow, challenge or block in milliseconds, with reasons in plain language. It sits on top of mandated 2FA and never replaces it.

WHAT'S DIFFERENT

1 Each payment is compared with **this user's own** history, not a global average.

2 Amount-aware: small payments are almost never interrupted; a large first-time transfer is checked closely.

3 The challenge fits the risk. A fingerprint stops an impostor. Only a pause and a second person stop a coached victim.

WHAT ASHA SEES IN SITUATION 3

> *"Police, CBI or RBI never ask you to move money over a call. We've paused this payment for 30 minutes and asked Rohan to confirm. You can cancel anytime."*
>
> Rohan, her son, gets Approve / Cancel on Telegram. No reply in 30 minutes cancels it.

THE SAME ₹85,000 PAYMENT, FOUR SITUATIONS

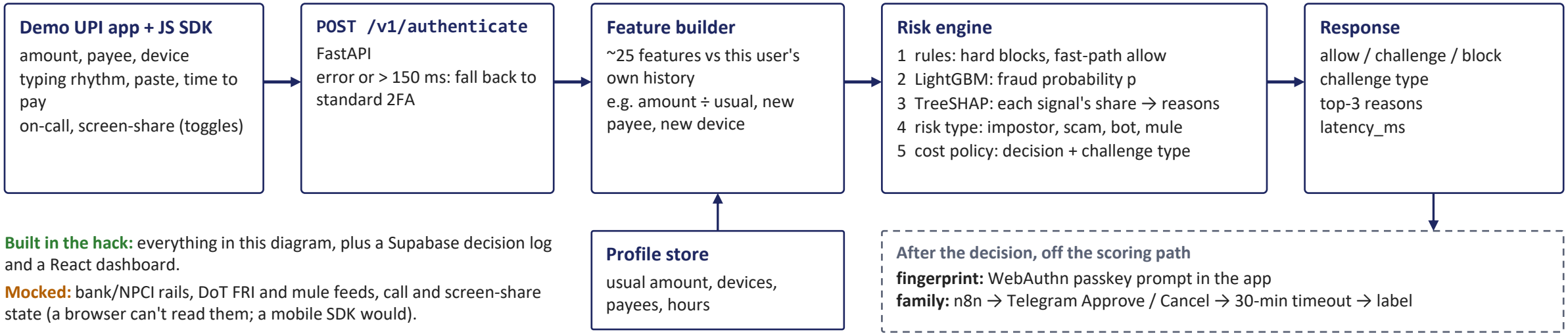
WHAT WE SEE	LIKELY RISK	RESPONSE
Usual payee, own phone, normal typing	None	**Allow, no extra step**
New phone, SIM changed 20 h ago, new city	Impostor	**Fingerprint (passkey)**
Own phone at home, on a call, new UPI ID pasted	Coached victim	**30-min hold + family can cancel**
Emulator + VPN, 15 attempts in 10 min	Bot	**Block**

REASONS THE API RETURNS FOR SITUATION 3 (TOP 3)

You're on a phone call while sending money
First payment to this receiver
Amount is 71× your usual ₹1,200

Technical Approach

> One API call: context in, an explained decision out, in milliseconds



Built in the hack: everything in this diagram, plus a Supabase decision log and a React dashboard.

Mocked: bank/NPCI rails, DoT FRI and mule feeds, call and screen-share state (a browser can't read them; a mobile SDK would).

STACK · ₹0 RUNNING COST

Python 3.11, FastAPI, LightGBM, shap on Render free tier · React (Vite) on Vercel · Supabase · n8n self-hosted + Telegram Bot API · WebAuthn

DATA

No public dataset has behaviour, device and transaction signals together. Synthetic generator: 5,000 users, 30 days, 4 labelled attack types, plus honest look-alikes (travel, new phone, rent). Sanity check on IEEE-CIS and PaySim.

DECISION RULE

Block if p ≥ 0.90 or a hard rule fires. Challenge if p ≥ ₹500 ÷ amount, kept between 0.05 and 0.60 (×0.6 for users 70+). Challenge type: lowest friction + p × amount × (1 − how well it stops this risk type).

Build Plan, Risks & Impact

> A deployed, working prototype in the hack, honest about its limits

1 · WHAT WE WILL BUILD

1 Live /v1/authenticate on Render, with the 2FA fail-safe

2 Risk engine with reasons, trained on synthetic data

3 Demo UPI app: passkey fingerprint and the n8n + Telegram family loop

4 Dashboard: live decisions, their reasons, latency

5 Replay: our policy vs RBI's blanket delay on the same traffic

48-HOUR PLAN

H0–8 data generator, API skeleton
H8–20 engine + /v1/authenticate
H20–34 app, passkeys, n8n loop
H34–44 dashboard, replay, load test
H44–48 deploy, rehearse

2 · RISKS & LIMITATIONS

Synthetic data
The model learns our generator, not real fraud. *Honest look-alikes, results per attack type, checks on public data; a bank pilot retrains on real history.*

Call state needs an SDK
A browser can't see calls or screen-sharing. *A missing signal counts as "unknown", never "safe".*

False positives
Holding a genuine urgent payment hurts. *Block only at p ≥ 0.90; challenge at most 5% of honest payments; cancel anytime.*

Privacy (DPDP Act)
Behaviour data is personal data. *Derived features only, hashed device IDs, a retention window.*

3 · EXPECTED IMPACT

Targets for the prototype:

≥ 80%
of scam-type fraud stopped, while challenging ≤ 5% of honest payments

≥ 90%
of honest ₹10,000+ transfers go through with no delay (a blanket rule delays all of them)

< 50 ms
p95 decision time, a small slice of UPI's 15-second window

Measured on held-out synthetic data and shown live in the demo. Baselines: OTP-only, a fixed threshold, RBI's blanket delay.